

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 12

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM3-108)

Scenario: A biotechnology company discovers suspicious commands in a sequencing platform during an overnight clinical run. The response plan names only the research director, who is unreachable, as authorized to pause the platform.

Which readiness change would BEST prevent this decision bottleneck?

- A. Require the overnight team to continue every clinical run regardless of risk.
- B. Document delegated pause authority, decision limits, alternates, and escalation paths.
- C. Give all laboratory personnel permanent authority to shut down every research system.
- D. Assign the equipment supplier sole authority over organizational incident decisions.

Question 2 (CISM3-109)

Which development should MOST clearly trigger an unscheduled incident-response plan review?

- A. A team changes the font used in monthly dashboards.
- B. A department renames its routine operations meeting.
- C. A noncritical laptop model reaches its standard refresh date.
- D. A corporate restructuring changes incident authority, critical-service ownership, and legal entities.

Question 3 (CISM3-110)

Scenario: An engineering group acquires two firms whose incident plans use different severity scales and crisis-activation rules. One subsidiary also relies on a parent-managed recovery site.

What should be established before the plans are approved?

- A. A common governance framework defining severity principles, interfaces, authority, dependencies, and escalation.
- B. A requirement that each subsidiary conceal incidents from the parent until closure.
- C. A rule that every subsidiary event activates the parent crisis team.
- D. One detailed technical procedure for all systems, regardless of architecture.

Question 4 (CISM3-111)

Scenario: A consumer-products company has a polished response plan, but exercises show outdated supplier contacts, no decision log owner, unclear insurer engagement, and no linkage to business continuity.

Which remediation would provide the GREATEST assurance?

- A. Add more pages describing malware families.
- B. Distribute the unchanged plan to additional technical staff.
- C. Ask the insurer to become incident commander during major events.
- D. Assign owners, repair plan interfaces, update dependencies, and validate them through exercise.

Question 5 (CISM3-112)

Scenario: An airport classifies baggage reconciliation as critical but omits its dependencies on identity services, message queues, scanning networks, and facility power.

What is the MOST important readiness risk?

- A. Analysts may retain more log data than expected.
- B. The baggage software may have a lower book value than supporting hardware.
- C. Every scanning error may be incorrectly treated as a public crisis.
- D. The stated recovery priority may fail because prerequisite capabilities are absent from planning.

Question 6 (CISM3-113)

Scenario: A tax-services portal has limited impact most of the year but becomes critical during statutory filing periods, when an hour of downtime creates severe customer and compliance consequences.

How should the impact analysis guide incident readiness?

- A. Define time-dependent priorities, staffing, and escalation for filing periods.
- B. Use the lowest annual impact rating throughout the year.
- C. Treat every minor portal alert as maximum severity in all seasons.
- D. Base readiness solely on the portal's server count.

Question 7 (CISM3-114)

Scenario: A specialty manufacturer has approved a five-hour recovery time objective for its formulation system but has not defined how much newly approved recipe data may be lost.

What should management approve NEXT?

- A. A target for the number of alerts reviewed per shift.
- B. A recovery point objective based on acceptable loss of formulation changes.
- C. A standard duration for technical interviews.
- D. A maximum number of participants in recovery exercises.

Question 8 (CISM3-115)

What is the PRIMARY measure of whether a business continuity workaround supports incident management?

- A. Whether the workaround uses the newest technology.
- B. Whether it sustains prioritized activity within approved capacity and time tolerances.
- C. Whether it prevents the incident from requiring investigation.
- D. Whether security owns every task in the workaround.

Question 9 (CISM3-116)

Scenario: A remote customer-support plan uses a voice service from the same carrier that supplies the primary contact center. The plan is intended for carrier outages.

Which recommendation BEST addresses the weakness?

- A. Increase endpoint monitoring without changing telecommunications.
- B. Keep the arrangement because remote work occurs in different buildings.
- C. Arrange and test an alternate communication path without the shared carrier dependency.
- D. Eliminate customer-support continuity requirements.

Question 10 (CISM3-117)

Scenario: A wholesaler can accept paper orders during an outage, but its procedure does not assign sequence numbers or define how orders will be reconciled after systems recover.

What improvement is MOST appropriate?

- A. Discard paper orders once online service resumes.
- B. Enter all orders without checking for duplicates.
- C. Allow each warehouse to invent a reconciliation method during the incident.
- D. Add controlled numbering, custody, validation, and post-recovery reconciliation steps.

Question 11 (CISM3-118)

Scenario: A professional association plans to restore remote access and member applications before the internal certificate authority required to authenticate both services.

How should the sequence be corrected?

- A. Assign every component the same recovery point objective.
- B. Let application vendors independently choose the order.
- C. Restore the public application first solely because members can see it.
- D. Restore the certificate authority before the dependent access and application services.

Question 12 (CISM3-119)

Scenario: A consulting firm confirms that immutable backups exist and concludes that disaster recovery is proven. It has never restored the data, started the applications, or tested interfaces.

Which validation activity should be required before relying on the backups?

- A. A controlled end-to-end restoration test covering integrity, applications, dependencies, interfaces, and objectives.
- B. A new inventory of backup file extensions.
- C. A review of office seating at the alternate location.
- D. Only a report showing the amount of backup storage consumed.

Question 13 (CISM3-120)

Which statement BEST describes maximum tolerable downtime?

- A. It is the longest disruption the business can tolerate before impact becomes unacceptable.
- B. It is the amount of data that may be lost during restoration.
- C. It is the service desk's target for closing ordinary tickets.
- D. It is always identical to the contractual service-level target.

Question 14 (CISM3-121)

Scenario: A robotics company rates incidents by device count. Unauthorized logic changes on one safety controller are rated below advertising software detected on hundreds of lobby tablets.

Which change would BEST improve classification?

- A. Use only the replacement cost of the affected devices.
- B. Add safety, integrity, information sensitivity, operational criticality, scope, and urgency to severity criteria.
- C. Let each responder assign severity without reference guidance.
- D. Give every controller alert the highest rating before assessment.

Question 15 (CISM3-122)

Scenario: A construction company's procedure says to notify executives if an event looks bad. Exercises produce late and inconsistent escalation for worker-safety and contractual issues.

What should replace this language?

- A. Escalation only after the incident is publicly reported.
- B. Escalation whenever an analyst receives more than one alert.
- C. Documented thresholds based on safety, business impact, information, scope, and applicable obligations.
- D. Automatic board notification for every blocked connection.

Question 16 (CISM3-123)

Scenario: A university uses categories for malware, misuse, outage, and privacy, but each category automatically receives the same priority and response team.

Which classification redesign would MOST improve response routing?

- A. Replace category and severity with estimated repair hours.
- B. Create a category for every individual application version.
- C. Separate incident type from impact-based severity and map both to expertise, authority, and escalation.
- D. Keep the model and send every report to more people.

Question 17 (CISM3-124)

Scenario: A satellite operator's exercise shows strong technical response but no trained privacy liaison, no alternate incident commander, and no executive-briefing capability.

Which action should be taken FIRST to improve readiness?

- A. Provide advanced reverse-engineering training to the board.
- B. Map competencies to response roles, assign trained personnel and alternates, and retest the gaps.
- C. Ask an external regulator to fill all missing internal roles.
- D. Remove privacy and executive injects from later exercises.

Question 18 (CISM3-125)

Scenario: A mortgage company repeats the same announced scenario with identical injects every six months. Participants now recite the expected decisions, and no new findings emerge.

How should the exercise program change?

- A. Stop recording results because the plan appears mature.
- B. Limit future testing to whether monitoring tools produce alerts.
- C. Vary scenarios and injects while measuring decision, coordination, and recovery objectives.
- D. Exclude leaders so analysts can complete the script faster.

Question 19 (CISM3-126)

Which exercise BEST tests senior-management coordination without affecting production services?

- A. An unannounced disconnection of the primary data center.
- B. A facilitated tabletop using evolving operational, legal, customer, and media injects.
- C. A routine scan of internet-facing systems.
- D. A count of employees who opened the response plan.

Question 20 (CISM3-127)

Scenario: A pension fund's exercise report says communication was effective but records no timestamps, decisions, objective results, gaps, or follow-up actions.

What should be required before closing the exercise?

- A. A statement that all participants enjoyed the exercise.
- B. Evidence against objectives, documented gaps, owned corrective actions, success criteria, and retesting.
- C. Removal of observations that could concern senior leaders.
- D. Approval based solely on completing the scheduled session.

Question 21 (CISM3-128)

What is the PRIMARY outcome of initial incident triage?

- A. An initial decision on incident status, impact, priority, and routing.
- B. A final determination of all root causes.
- C. A completed public-notification package.
- D. A permanent redesign of every affected control.

Question 22 (CISM3-129)

Scenario: A transit operator receives reports of blocked bulk email and unexplained changes to speed restrictions displayed to train controllers.

Which report requires FIRST assessment?

- A. The email report because it contains more individual events.
- B. The speed-restriction changes because potential integrity and safety impact demand urgent triage.
- C. Neither until the vendor confirms malicious intent.
- D. Both reports after the monthly metrics meeting.

Question 23 (CISM3-130)

Scenario: Delivery partners can access a retailer's logistics system but cannot use its employee incident portal. They currently report concerns through individual account managers, causing delays.

Which management action is MOST appropriate?

- A. Provide an authenticated, monitored reporting route with intake, acknowledgment, and escalation procedures.
- B. Treat partner reports as low priority by default.
- C. Require partners to complete their own investigation before reporting.
- D. Ask account managers to preserve forensic evidence on personal devices.

Question 24 (CISM3-131)

Scenario: A compromised warehouse-control system is directing autonomous vehicles into occupied work areas. Stopping the controller may erase volatile process data.

Which immediate stabilization decision is MOST appropriate?

- A. Place operations in a safe state through authorized procedures, document actions, and preserve feasible evidence.
- B. Allow unsafe movement until every volatile artifact is captured.
- C. Destroy all controllers immediately without recording the change.
- D. Wait for the system integrator to decide whether worker-safety rules apply.

Question 25 (CISM3-132)

Scenario: A regional administrator who approved disputed access changes offers to lead the investigation because no one else knows the environment as well.

What is the BEST governance decision?

- A. Assign an appropriately independent lead, preserve access to expertise, restrict privileges as authorized, and involve legal and human resources.
- B. Let the administrator investigate alone and provide an oral conclusion.
- C. End the investigation unless the administrator consents to review.
- D. Publicly attribute the incident before evidence is evaluated.

Question 26 (CISM3-133)

Scenario: Security footage relevant to suspected equipment theft is copied to several removable drives, but none is labeled and no collection time, hash, custodian, or transfer log exists.

What is the MOST significant issue?

- A. Evidence integrity and provenance may be challenged because custody was undocumented.
- B. The footage automatically becomes proof of criminal intent.
- C. The incident must be reclassified as a disaster.
- D. The organization must shorten every technology recovery objective.

Question 27 (CISM3-134)

Scenario: During a fraud investigation, local law enforcement asks an analyst to provide customer records immediately through a personal file-sharing account. The scope and legal authority of the request are unclear.

Which coordination action should occur before records are transferred?

- A. Coordinate legal counsel and law enforcement on authority, transfer, and preservation.
- B. Ask the analyst to decide which laws apply.
- C. Notify customers that law enforcement has proven fraud.
- D. Send all available records to avoid delaying the investigation.

Question 28 (CISM3-135)

Which statement BEST describes short-term containment?

- A. It permanently removes every root cause before service recovery.
- B. It replaces the need to preserve evidence.
- C. It limits immediate harm while sustainable containment or remediation is developed.
- D. It transfers incident accountability to a technology supplier.

Question 29 (CISM3-136)

Scenario: An education platform confirms that one tenant's stolen integration token is exporting records. Disabling all tenant integrations would interrupt examinations at hundreds of schools.

What is the MOST appropriate containment action?

- A. Revoke the token, isolate the integration, preserve evidence, and monitor activity.
- B. Leave the token active until examinations end.
- C. Disable the entire platform without assessing alternatives.
- D. Erase integration logs before isolating the connection.

Question 30 (CISM3-137)

Scenario: A hotel's door-control system has an exploitable flaw that cannot be patched for eight weeks. Segmentation and local-only administration reduce exposure but require additional staffing.

Which strategy is BEST?

- A. Restore unrestricted remote access to reduce staffing costs.
- B. Accept the flaw indefinitely without accountable approval.
- C. Use tested restrictions, monitoring, an expiration date, and tracked remediation.
- D. Disconnect every guest-room lock without considering physical safety.

Question 31 (CISM3-138)

Scenario: Online posts claim that a charity's donor database was sold. Responders have verified suspicious authentication activity but have not confirmed database access or data extraction.

Which communication is MOST appropriate now?

- A. Confirm the sale so the organization appears decisive.
- B. Publish raw authentication logs for public analysis.
- C. Issue an approved statement with verified facts, current actions, and updates.
- D. Avoid all communication until every corrective action is complete.

Question 32 (CISM3-139)

Scenario: A logistics company discovers service disruption that may fall within its cyber-insurance notice clause and several customer contracts. Impact and cause are still being assessed.

Which action should occur FIRST?

- A. Wait for the final post-incident report before reading the policies and contracts.
- B. Use a deadline from an unrelated jurisdiction for every recipient.
- C. Tell every customer that its data was stolen.
- D. Map known facts with legal and business owners to notice requirements.

Question 33 (CISM3-140)

Scenario: During an identity-service incident, executives receive pages of authentication events while responders receive only the estimated reputational impact.

Which reporting change would BEST support both groups?

- A. Send identical raw logs to every stakeholder.
- B. Allow each team to publish independent scope estimates.
- C. Tailor updates from one verified record to audience decisions and cadence.
- D. Stop scheduled briefings and respond only when executives complain.

Question 34 (CISM3-141)

Scenario: A cyberattack disrupts food-product traceability across multiple plants during an active safety recall. Routine incident calls exclude corporate crisis leadership and public affairs.

Which escalation action is required NEXT?

- A. Activate the crisis plan and coordinate safety, operational, legal, executive, regulator, customer, and public communications.
- B. Allow plant technicians to answer media questions independently.
- C. Wait until engineers prove the attack's root cause.
- D. Close the cyber incident because the recall team owns product safety.

Question 35 (CISM3-142)

Scenario: A research institute has several snapshots after a storage compromise. The newest snapshot contains unexplained privileged-account changes, while an older snapshot has not yet been tested for application consistency.

What should be done before production restoration?

- A. Use the newest snapshot solely to minimize data loss.
- B. Validate candidate recovery points in isolation for integrity, cleanliness, consistency, and business acceptability.
- C. Restore directly into production and investigate afterward.
- D. Delete all snapshots because one may be affected.

Question 36 (CISM3-143)

Which evidence is MOST important before declaring an affected service recovered?

- A. Confirmation that the vendor's website is available.
- B. Proof that no security incident can ever affect the service again.
- C. Validation that required functionality, data integrity, security, dependencies, and business acceptance criteria are satisfied.
- D. Evidence that the response team has ended every meeting.

Question 37 (CISM3-144)

Scenario: A benefits system has been rebuilt after unauthorized record changes. The application is available, but totals do not match the authoritative payroll feed.

Who should approve normal processing, and when?

- A. The infrastructure engineer as soon as servers respond.
- B. Any analyst once the recovery time target expires.
- C. The software vendor based only on application uptime.
- D. The business owner and incident authority after agreed validation criteria are met.

Question 38 (CISM3-145)

Scenario: An emergency-dispatch organization can restore call intake securely, but historical reporting depends on an interface that has not completed validation.

Which recovery approach is MOST appropriate?

- A. Reconnect all interfaces to report full recovery.
- B. Restore validated call intake gradually and communicate residual limitations.
- C. Keep call intake offline until historical reporting is ready.
- D. Let individual application owners reconnect components without coordination.

Question 39 (CISM3-146)

Scenario: After a QR-code phishing incident, a retailer finds that its assessments, training, and reporting guidance address only links in email. Several store managers did not recognize the reporting route.

Which improvement package would BEST address the findings?

- A. Record the incident but retain all existing assumptions.
- B. Prohibit all use of QR codes without business analysis.
- C. Depend only on a technical email filter.
- D. Reassess the threat, update guidance, train roles, and test changes.

Question 40 (CISM3-147)

Scenario: A vendor misconfiguration exposed project documents. A manager wants the review to focus only on the employee who accepted the vendor's change request.

How should the review be structured?

- A. Exclude vendor-management and process owners.
- B. Examine contracting, approval, verification, and oversight while handling personnel matters separately.
- C. Cancel the review because an individual approved the request.
- D. Begin by publishing the employee's name.

Question 41 (CISM3-148)

Scenario: A digital-signage outage followed an expired signing certificate. Review evidence shows no certificate inventory owner, alerts routed to a disabled account, and no renewal escalation.

Which finding BEST represents the root cause?

- A. Screens displayed error messages during the outage.
- B. Certificate governance failed to assign ownership, monitor expiration, and escalate renewal.
- C. Responders restarted signage players.
- D. Employees received questions from visitors.

Question 42 (CISM3-149)

Scenario: Months after a cloud-access incident, remediation tasks remain scattered across email. Several have no owner, deadline, evidence, or approved exception.

Which action should the information security manager take?

- A. Create a governed action register with priority, owners, dates, validation evidence, escalation, and formal exception approval.
- B. Close all tasks because the original service is operating.
- C. Restrict progress review to the responders who opened the incident.
- D. Accept verbal statements that work is probably complete.

Question 43 (CISM3-150)

Scenario: A healthcare network reports incident volume and analyst hours but cannot explain whether patient impact, response speed, repeated causes, or overdue remediation are improving.

Which metric set would provide the BEST insight?

- A. Only the number of alerts generated each week.
- B. Only the percentage of incidents administratively closed.
- C. Only the average hours worked by each responder.
- D. Trends in impact, response time, recurrence, recovery, and remediation aging.

Answer Key

Domain IV - Incident Management

1 B	2 D	3 A	4 D	5 D
6 A	7 B	8 B	9 C	10 D
11 D	12 A	13 A	14 B	15 C
16 C	17 B	18 C	19 C	20 B
21 A	22 B	23 A	24 A	25 C
26 A	27 A	28 C	29 A	30 C
31 C	32 D	33 C	34 A	35 B
36 C	37 D	38 B	39 D	40 B
41 B	42 D	43 D		

Detailed Explanations

Question 1 (CISM3-108)

Correct answer: B - Document delegated pause authority, decision limits, alternates, and escalation paths.

Bounded delegated authority and named alternates enable timely action while preserving accountability. Continuing despite risk leaves the gap open, universal shutdown authority is excessive, and the supplier cannot own the organization's response decision.

Question 2 (CISM3-109)

Correct answer: D - A corporate restructuring changes incident authority, critical-service ownership, and legal entities.

The restructuring changes authority, ownership, scope, and potentially legal obligations, making immediate review necessary. Cosmetic reporting changes, meeting names, and routine equipment refreshes do not materially alter incident readiness.

Question 3 (CISM3-110)

Correct answer: A - A common governance framework defining severity principles, interfaces, authority, dependencies, and escalation.

A common framework aligns decisions and dependencies while allowing suitable local procedures. Concealing incidents prevents oversight, universal crisis activation is disproportionate, and one technical procedure cannot address distinct environments.

Question 4 (CISM3-111)

Correct answer: D - Assign owners, repair plan interfaces, update dependencies, and validate them through exercise.

The identified failures concern ownership, coordination, dependencies, and validation, so a governed repair followed by exercise provides the strongest assurance. More technical content or distribution does not fix the gaps, and an insurer does not command the organization's response.

Question 5 (CISM3-112)

Correct answer: D - The stated recovery priority may fail because prerequisite capabilities are absent from planning.

A recovery priority is not feasible unless its prerequisites are identified and sequenced. Log volume and asset value are separate considerations, and missing dependencies do not automatically make every error a crisis.

Question 6 (CISM3-113)

Correct answer: A - Define time-dependent priorities, staffing, and escalation for filing periods.

Time-dependent criteria align preparedness with predictable periods of high consequence. A low annual average understates peak exposure, permanent maximum severity is inefficient, and server count is not a measure of business impact.

Question 7 (CISM3-114)

Correct answer: B - A recovery point objective based on acceptable loss of formulation changes.

The recovery point objective states the acceptable data-loss interval and complements the time objective. Alert volume, interview duration, and exercise attendance do not define recoverable business data.

Question 8 (CISM3-115)

Correct answer: B - Whether it sustains prioritized activity within approved capacity and time tolerances.

A continuity workaround succeeds when it sustains required business activity within approved tolerances while response proceeds. Technology age and security ownership are not primary outcomes, and continuity does not eliminate the need to investigate an incident.

Question 9 (CISM3-116)

Correct answer: C - Arrange and test an alternate communication path without the shared carrier dependency.

A credible alternate must avoid the failure it is designed to survive and must be tested. Different buildings do not remove a carrier dependency, endpoint monitoring does not restore voice service, and eliminating the requirement abandons the business need.

Question 10 (CISM3-117)

Correct answer: D - Add controlled numbering, custody, validation, and post-recovery reconciliation steps.

Controlled records and reconciliation preserve transaction integrity and support safe recovery. Discarding orders loses business data, blind entry creates duplicates, and ad hoc local methods produce inconsistent and unauditable results.

Question 11 (CISM3-118)

Correct answer: D - Restore the certificate authority before the dependent access and application services.

The certificate authority is a prerequisite, so it must be restored before dependent services can function securely. Equal data-loss objectives do not solve sequence, visibility does not override dependency, and independent vendor choices undermine coordinated recovery.

Question 12 (CISM3-119)

Correct answer: A - A controlled end-to-end restoration test covering integrity, applications, dependencies, interfaces, and objectives.

Backup existence is not proof of recoverability or service usability. End-to-end testing validates the complete recovery chain, whereas storage volume, file extensions, and seating do not show that prioritized services can be restored.

Question 13 (CISM3-120)

Correct answer: A - It is the longest disruption the business can tolerate before impact becomes unacceptable.

Maximum tolerable downtime expresses the outer business limit for disruption and informs recovery planning. Acceptable data loss is the recovery point objective, ticket targets are operational metrics, and contractual service levels are not necessarily identical to business tolerance.

Question 14 (CISM3-121)

Correct answer: B - Add safety, integrity, information sensitivity, operational criticality, scope, and urgency to severity criteria.

Multidimensional criteria capture the potentially severe safety and integrity implications of a single controller. Device cost is incomplete, unguided judgment is inconsistent, and automatic maximum ratings ignore verified context and impact.

Question 15 (CISM3-122)

Correct answer: C - Documented thresholds based on safety, business impact, information, scope, and applicable obligations.

Objective impact- and obligation-based thresholds support timely, consistent escalation. Public reporting is too late, alert count is an inadequate proxy, and escalating all blocked activity overwhelms senior decision makers.

Question 16 (CISM3-123)

Correct answer: C - Separate incident type from impact-based severity and map both to expertise, authority, and escalation.

Separating type and severity enables suitable expertise and urgency for different circumstances. Version-level categories become unmanageable, repair hours omit broader impact, and wider distribution does not correct poor routing.

Question 17 (CISM3-124)

Correct answer: B - Map competencies to response roles, assign trained personnel and alternates, and retest the gaps.

Competency mapping, designated personnel, alternates, and retesting directly address the identified capability gaps. Technical board training is misaligned, removing injects hides weaknesses, and regulators do not staff the organization's response structure.

Question 18 (CISM3-125)

Correct answer: C - Vary scenarios and injects while measuring decision, coordination, and recovery objectives.

Varied, objective-based exercises show whether teams can adapt rather than memorize. Stopping documentation, narrowing tests to tools, or excluding leaders would reduce assurance over the management capabilities being tested.

Question 19 (CISM3-126)

Correct answer: C - A routine scan of internet-facing systems.

A facilitated tabletop can challenge leadership decisions and cross-functional coordination without production disruption. Live disconnection is unnecessarily risky, a scan tests controls, and document-access counts do not demonstrate response capability.

Question 20 (CISM3-127)

Correct answer: B - Evidence against objectives, documented gaps, owned corrective actions, success criteria, and retesting.

Objective evidence and tracked corrective action make the exercise useful for readiness improvement. Participant satisfaction, suppressed findings, and completion alone do not demonstrate that the plan or team performed effectively.

Question 21 (CISM3-128)

Correct answer: A - An initial decision on incident status, impact, priority, and routing.

Triage establishes whether reported activity should be handled as an incident and assigns initial priority and routing. Root cause, public notification, and permanent redesign depend on later facts and authorization.

Question 22 (CISM3-129)

Correct answer: B - The speed-restriction changes because potential integrity and safety impact demand urgent triage.

Potentially altered safety information has much greater immediate consequence than blocked bulk email. Volume alone does not determine priority, and waiting for meetings or proof of intent could allow serious operational harm.

Question 23 (CISM3-130)

Correct answer: A - Provide an authenticated, monitored reporting route with intake, acknowledgment, and escalation procedures.

A monitored route enables prompt, consistent intake from third parties with relevant access. Proof requirements and default low priority delay response, while personal-device evidence handling creates additional security and custody risks.

Question 24 (CISM3-131)

Correct answer: A - Place operations in a safe state through authorized procedures, document actions, and preserve feasible evidence.

Worker safety takes priority over perfect evidence preservation, while coordinated documentation and feasible collection should continue. Leaving the hazard active is unacceptable, undocumented destruction harms investigation, and safety authority remains with the organization.

Question 25 (CISM3-132)

Correct answer: C - End the investigation unless the administrator consents to review.

Independent leadership protects objectivity while controlled technical input can still be used. Self-investigation creates a conflict, consent does not determine organizational authority, and public attribution before validation is premature.

Question 26 (CISM3-133)

Correct answer: A - Evidence integrity and provenance may be challenged because custody was undocumented.

Unlabeled copies and missing handling records make it difficult to prove authenticity, integrity, and provenance. They do not establish intent, define a disaster, or justify unrelated changes to recovery objectives.

Question 27 (CISM3-134)

Correct answer: A - Coordinate legal counsel and law enforcement on authority, transfer, and preservation.

Legal coordination and approved channels ensure the request is valid, proportionate, secure, and properly documented. Immediate informal transfer risks privacy and custody failures, analysts should not make legal determinations, and customer claims would be premature.

Question 28 (CISM3-135)

Correct answer: C - It limits immediate harm while sustainable containment or remediation is developed.

Short-term containment reduces immediate exposure and buys time for durable remediation. It does not necessarily remove root causes, eliminate evidence needs, or transfer accountability.

Question 29 (CISM3-136)

Correct answer: A - Revoke the token, isolate the integration, preserve evidence, and monitor activity.

Targeted revocation and isolation stop the confirmed path while limiting collateral impact and preserving investigation data. Waiting allows harm to continue, total shutdown may be disproportionate, and erasing logs destroys useful evidence.

Question 30 (CISM3-137)

Correct answer: C - Use tested restrictions, monitoring, an expiration date, and tracked remediation.

A controlled, approved, monitored, time-bounded measure reduces risk while permanent remediation proceeds. Cost alone does not justify exposure, indefinite acceptance bypasses accountability, and wholesale disconnection may create safety and operational harm.

Question 31 (CISM3-138)

Correct answer: C - Issue an approved statement with verified facts, current actions, and updates.

A fact-based holding statement provides timely information without speculation. Confirming an unsupported claim or releasing raw logs creates harm, while extended silence can worsen confusion during a visible investigation.

Question 32 (CISM3-139)

Correct answer: D - Map known facts with legal and business owners to notice requirements.

Early coordinated review protects coverage and contractual compliance while communications remain grounded in facts. Unrelated deadlines are unreliable, asserting theft may be false, and waiting for a final report could miss required notice windows.

Question 33 (CISM3-140)

Correct answer: C - Tailor updates from one verified record to audience decisions and cadence.

A single authoritative record preserves factual consistency, while tailored summaries make information actionable for different roles. Uniform raw data creates noise, independent estimates conflict, and reactive communication weakens oversight.

Question 34 (CISM3-141)

Correct answer: A - Activate the crisis plan and coordinate safety, operational, legal, executive, regulator, customer, and public communications.

The combination of a cyberattack, impaired traceability, and an active recall requires enterprise crisis coordination immediately. Root cause can follow, independent media responses create inconsistency, and safety ownership does not end the cyber incident.

Question 35 (CISM3-142)

Correct answer: B - Validate candidate recovery points in isolation for integrity, cleanliness, consistency, and business acceptability.

Recovery should use a tested trustworthy source selected with both security and business data-loss needs in mind. Recency alone is unsafe, discarding every snapshot is unsupported, and production testing risks reinfection or corrupted restoration.

Question 36 (CISM3-143)

Correct answer: C - Validation that required functionality, data integrity, security, dependencies, and business acceptance criteria are satisfied.

Recovery requires evidence that the service is trustworthy and fit for intended business use. Zero future risk cannot be proven, vendor-site availability is irrelevant, and ending response meetings does not validate the restored service.

Question 37 (CISM3-144)

Correct answer: D - The business owner and incident authority after agreed validation criteria are met.

Normal processing requires validated data integrity and accountable business acceptance, not infrastructure availability alone. A vendor cannot accept organizational business risk, and reaching a time target does not override failed reconciliation.

Question 38 (CISM3-145)

Correct answer: B - Restore validated call intake gradually and communicate residual limitations.

Phased recovery restores the critical validated function while controlling risk from the unresolved interface. Full reconnection sacrifices assurance, keeping intake offline causes unnecessary impact, and uncoordinated restoration can reintroduce risk.

Question 39 (CISM3-146)

Correct answer: D - Reassess the threat, update guidance, train roles, and test changes.

Post-incident improvement should update risk assumptions, human procedures, reporting, training, and testing based on observed conditions. No change forfeits learning, email filtering misses the channel, and a blanket prohibition may be disproportionate.

Question 40 (CISM3-147)

Correct answer: B - Examine contracting, approval, verification, and oversight while handling personnel matters separately.

The review should identify systemic conditions that enabled the exposure and produce sustainable improvements. Excluding owners, public blame, or cancellation undermines candor and leaves process weaknesses unresolved.

Question 41 (CISM3-148)

Correct answer: B - Certificate governance failed to assign ownership, monitor expiration, and escalate renewal.

The failed ownership and lifecycle process explains why an expected expiration caused an outage. Error displays and visitor questions are symptoms, while restarts are response actions rather than the underlying cause.

Question 42 (CISM3-149)

Correct answer: D - Accept verbal statements that work is probably complete.

A governed register makes improvement measurable and accountable and ensures incomplete work becomes an explicit risk decision. Service operation, unsupported verbal claims, and narrow responder-only review do not prove effective remediation.

Question 43 (CISM3-150)

Correct answer: D - Trends in impact, response time, recurrence, recovery, and remediation aging.

A balanced set connects incident operations to business consequence, timeliness, repeated causes, recovery, and remediation. Alert, closure, or labor measures alone can be misleading and do not show whether risk and capability are improving.